

Phase 1

Information Gathering & Enumeration

Network Discovery

Kali (Attacker Machine) IP: 192.168.56.101

Network range: 192.168.56.0/24

```
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:4a:f3:6e brd ff:ff:ff:ff:ff:ff
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:b3:16:03 brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
       valid_lft 491sec preferred_lft 491sec
```

Target IP(Metasploitable Machine): 192.168.56.102

```
o access official Ubuntu documentation, please visit:
ttp://help.ubuntu.com/
o mail.
sfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:e7:87:b8
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fee7:87b8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188 (1.1 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000
```

The attacker machine was assigned IP address 192.168.56.101 with a /24 subnet mask, indicating the internal network range 192.168.56.0/24. The Metasploitable2 target was identified at 192.168.56.102 within the same isolated network.

TCP SYN Scan (-sS)

Open Ports and Services Discovered

PORT	SERVICE	DESCRIPTION
21	FTP	FILE TRANSFER PROTOCOL
22	SSH	SECURE SHELL REMOTE ACCESS
23	TELNET	UNENCRYPTED REMOTE LOGIN
25	SMTP	MAIL SERVICE
53	DNS	DOMAIN NAME SERVICE
Etc as shown in the screenshot below		

```

(kali㉿kali)-[~]
$ sudo nmap -sS -p- 192.168.56.102
[sudo] password for kali:
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-09 17:47 UTC
Stats: 0:00:04 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for 192.168.56.102
Host is up (0.00044s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      Host    STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
33990/tcp open  unknown
34483/tcp open  unknown
45212/tcp open  unknown
52145/tcp open  unknown
MAC Address: 08:00:27:E7:87:B8 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 16.55 seconds

(kali㉿kali)-[~]
$ █

```

Security Observations (Critical Section)

This system is **highly vulnerable** due to:

1. Excessive exposed services

- More than 25 open ports detected
- Many unnecessary services running

2. Insecure protocols

- Telnet (Port 23) sends credentials in plaintext
- FTP (Port 21) often unencrypted
- rsh services (512–514) → outdated and insecure

3. Known vulnerable services

- distccd (3632) historically exploitable
- VNC (5900) weak/no authentication risk
- SMB (139/445) common attack vector
- MySQL/PostgreSQL exposed externally

4. Backdoor-like services

- Port 1524 (ingreslock), known Metasploitable backdoor shell

Service Banners

After running `sudo nmap -sV -sC 192.168.56.102` these banners were detected;

Port	Service Banner Discovered
21	vsftpd 2.3.4
22	OpenSSH 4.7p1 Debian
23	Linux telnetd
25	Postfix smtpd
53	ISC BIND 9.4.2
80	Apache httpd 2.2.8 (Ubuntu)

Port	Service Banner Discovered
111	rpcbind 2
139	Samba smbd 3.X-4.X
445	Samba 3.0.20-Debian
512	Netkit rexecd
513	rlogin service
514	Netkit rshd
1099	GNU Classpath gmiregistry
1524	Metasploitable bind shell
2049	NFS 2-4
2121	ProFTPD 1.3.1
3306	MySQL 5.0.51a
5432	PostgreSQL 8.3
5900	VNC protocol 3.3
6667	UnrealIRCd
8009	Apache JServ AJP13
8180	Apache Tomcat 5.5

```
Ethical-Hacker-Kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

File Actions Edit View Help

Nmap done: 1 IP address (1 host up) scanned in 16.55 seconds

[~] sudo nmap -sV -sC 192.168.56.102
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-09 17:51 UTC
Nmap Scan report for 192.168.56.102
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.56.101
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Ubuntu (protocol 2.0)
|_ssh-hostkey:
|_  1024 68:0f:cfe:cb:5f:6a:7a:d0:90:24:fa:c4:d5:8c:cd (DSA)
|_  2048 54:56:2a:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-cert: Subject: commonName=subuntu@base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-10T14:07:45
|_smtp-command: Metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-06-09T17:51:57+00:00; +9s from scanner time.
|_ssl-v2:
|_  SSLv2 supported
|_  ciphers:
|_    SSLv2_RC2_128_CBC_WITH_MD5
|_    SSLv2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSLv2_DES_64_CBC_WITH_MD5
|_    SSLv2_RC4_128_WITH_MD5
|_    SSLv2_DES_192_EDE3_CBC_WITH_MD5
|_    SSLv2_RC4_128_EXPORT40_WITH_MD5
|_  53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_  bind.version: 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind       2 (RPC #100000)
|_rpcinfo:
|_  program version port/proto service
|_  100000 2 111/tcp rpcbind
|_  100000 2 111/udp rpcbind
|_  100003 2,3,4 2049/tcp nfs
|_  100003 2,3,4 2049/udp nfs
|_  100005 1,2,3 4232/tcp mountd
|_  100005 1,2,3 46616/udp mountd
|_  100021 1,3,4 33998/tcp nlockmgr
|_  100021 1,3,4 38337/udp nlockmgr
|_  100024 1 33522/udp status
|_  100024 1 52145/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  smb           Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login         netkit-rsh rlogind
514/tcp   open  shell         Netkit rshd
1699/tcp  open  java-rmi      000 Classpath rmiregistry
1524/tcp  open  bindshell     Metasploitable2 root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2123/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-Jubuntu5
|_mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-Jubuntu5
|_  Thread ID: 8
|_  Capabilities Flags: 43564
|_  Some Capabilities: Support1Auth, SupportsTransactions, ConnectWithDatabase, Speaks41ProtocolNew, SwitchToS
|_  Status: Autocommit
|_  salt: "f(weasy)4558,Mf('M
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-06-09T17:51:57+00:00; +18s from scanner time.
|_ssl-cert: Subject: commonName=subuntu@base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-10T14:07:45
5900/tcp  open  vnc           VNC (protocol 3.3)
|_vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_  VNC Authentication (2)
|_  Security types:
|_  VNC Authentication (2)
6800/tcp  open  x11           (Access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTIONS request
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
```

```
Ethical-Hacker-Kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

File Actions Edit View Help

|_dns-nsid:
|_  bind.version: 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind       2 (RPC #100000)
|_rpcinfo:
|_  program version port/proto service
|_  100000 2 111/tcp rpcbind
|_  100000 2 111/udp rpcbind
|_  100003 2,3,4 2049/tcp nfs
|_  100003 2,3,4 2049/udp nfs
|_  100005 1,2,3 4232/tcp mountd
|_  100005 1,2,3 46616/udp mountd
|_  100021 1,3,4 33998/tcp nlockmgr
|_  100021 1,3,4 38337/udp nlockmgr
|_  100024 1 33522/udp status
|_  100024 1 52145/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  smb           Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login         netkit-rsh rlogind
514/tcp   open  shell         Netkit rshd
1699/tcp  open  java-rmi      000 Classpath rmiregistry
1524/tcp  open  bindshell     Metasploitable2 root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2123/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-Jubuntu5
|_mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-Jubuntu5
|_  Thread ID: 8
|_  Capabilities Flags: 43564
|_  Some Capabilities: Support1Auth, SupportsTransactions, ConnectWithDatabase, Speaks41ProtocolNew, SwitchToS
|_  Status: Autocommit
|_  salt: "f(weasy)4558,Mf('M
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-06-09T17:51:57+00:00; +18s from scanner time.
|_ssl-cert: Subject: commonName=subuntu@base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-10T14:07:45
5900/tcp  open  vnc           VNC (protocol 3.3)
|_vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_  VNC Authentication (2)
|_  Security types:
|_  VNC Authentication (2)
6800/tcp  open  x11           (Access denied)
6667/tcp  open  irc           UnrealIRCd
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTIONS request
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
```

Copy Selection

Paste Clipboard

Paste Selection

Zoom in

Zoom out

Zoom reset

Clear Active Terminal

Split Terminal Horizontally

Split Terminal Vertically

Collapse Subterminal

Toggle Menu

Hide Window Borders

Preferences...

Ctrl+Shift+C

Ctrl+Shift+V

Shift+Ins

Ctrl++

Ctrl+-

Ctrl+0

Ctrl+Shift+X

Ctrl+Shift+D

Ctrl+Shift+R

Ctrl+Shift+E

Ctrl+Shift+M

POTENTIAL ATTACK SURFACES

FTP	Port 21,	Unauthorized file access
SSH	Port 22 open	Brute-force attacks
Telnet	Port 23 open	Credential interception
SMTP	Port 25 open	Email enumeration/spam abuse
DNS	Port 53 BIND 9.4.2	DNS attacks/misconfiguration
Web Server	Apache 2.2.8	Web vulnerabilities
SMB	Ports 139/445 Samba	File sharing exploitation
rsh	Ports 512-514	Remote command execution
Java RMI	Port 1099	Remote object exploitation
Bind Shell	Port 1524	Unauthorized root access
NFS	Port 2049	File exposure
FTP Alternative	Port 2121 ProFTPD	Weak authentication
MySQL	Port 3306	Database attacks
PostgreSQL	Port 5432	Database attacks
VNC	Port 5900	Remote access attacks
IRC	Port 6667 UnrealIRCd	Known vulnerable service
Tomcat	Port 8180	Web application attacks

```
Ethical-Hacker-Kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali -
File Actions Edit View Help
3386/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities Flags: 43564
|_ Some Capabilities: Support4Auth, SupportsTransactions, ConnectWithDatabase, Speaks4ProtocolNew, SwitchToSSLAfterHandshake, LongColumnFlag, SupportsCompression
|_ Status: Autocommit
|_ Salt: 'ff[V4+yyj(555%MI'`M
5832/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-date: 2026-06-09T17:51:57+00:00; +18s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu00-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2018-03-17T14:07:45
|_ Not valid after: 2018-04-10T14:07:45
5900/tcp open  vnc        VNC (protocol 3.3)
|_ vnc-info:
|_ Protocol version: 3.3
|_ Security types:
|_ VNC Authentication (2)
6000/tcp open  x11        (access denied)
6600/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_ http-title: Apache Tomcat/5.5
|_ http-favicon: Apache Tomcat
|_ http-server-header: Apache-Coyote/1.1
MAC Address: 08:00:27:1F:87:38 (Oracle VM VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: o:/linux/linux_kernel

Host script results:
|_ smb-os-discovery:
|_ OS: Unix (Samba 3.0.20-Debian)
|_ Computer name: metasploitable
|_ NetBIOS computer name:
|_ Domain name: localdomain
|_ FQDN: metasploitable.localdomain
|_ System time: 2025-06-09T13:51:50-04:00
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 1h40m9s, deviation: 2h00m00s, median: 9s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.49 seconds
kali@kali:~$
```

WEB ENUMERATION

1. Web Server Identified

From previous Nmap scan:

Finding	Result
Web Server	Apache HTTP Server
Version	Apache 2.2.8
Target URL	http://192.168.56.102
Additional Web Server	Apache Tomcat 5.5
Tomcat URL	http://192.168.56.102:8180

2. Directories Discovered

DIRB discovered the following:

Directory	HTTP Status	Implication
/cgi-bin/	403	CGI directory exists but access denied
/dav/	200	WebDAV directory accessible
/phpMyAdmin/	200	Database management application
/test/	200	Test directory exposed
/twiki/	200	TWiki web application
/server-status	403	Apache status page exists

3. Web Applications Discovered

A. phpMyAdmin

Location:

<http://192.168.56.102/phpMyAdmin/>

Purpose:

- MySQL database administration interface

Security concern:

- Exposed database management panel
- Possible brute-force attack
- Database compromise if credentials are weak

B. TWiki

Location:

<http://192.168.56.102/twiki/>

Your scan found:

/twiki/bin/register

/twiki/bin/passwd

/twiki/bin/edit

/twiki/bin/upload

This means:

- user registration exists
- password functions exist
- file upload functionality exists

Security concerns:

- User enumeration
- Weak authentication
- Possible upload abuse

C. WebDAV

Location:

http://192.168.56.102/dav/

Important finding:

Your DIRB reported:

WARNING: Directory IS LISTABLE

Meaning:

The directory contents may be visible.

Risk:

- Information disclosure
- Unauthorized file access

D. PHP Information Page

Found:

/phpinfo.php

This is a very important finding.

Purpose:

Displays PHP configuration.

Risk:

Information leakage:

- PHP version
- modules installed
- server configuration

4. Login Portals Identified

Portal	Location	Purpose
phpMyAdmin Login	/phpMyAdmin/	MySQL management
TWiki User Functions	/twiki/bin/register	User management
TWiki Password Page	/twiki/bin/passwd	Password management
Tomcat	Port 8180	Web application server

5. Potential Web Attack Surfaces

Finding	Evidence	Risk
Exposed phpMyAdmin	/phpMyAdmin/	Database attacks
Directory listing	/dav/	File disclosure
PHP info exposure	/phpinfo.php	Server information leakage
TWiki application	/twiki/	Application vulnerabilities

Finding	Evidence	Risk
WebDAV enabled	/dav/	File manipulation risk
Old Apache version	Apache 2.2.8	Known vulnerabilities

PHASE 2

Password Security Assessment

Multiple accounts exist including service accounts.

Risk:

- Attackers can enumerate usernames
- Weak passwords can be targeted
- Unnecessary accounts increase attack surface

Identified User Accounts

Username	UID	Home Directory	Login Shell	Account Type
root	0	/root	/bin/bash	Administrator
msfadmin	1000	/home/msfadmin	/bin/bash	Normal User
postgres	108	/var/lib/postgresql	/bin/bash	Database Admin
user	1001	/home/user	/bin/bash	Normal User
service	1002	/home/service	/bin/bash	Normal User

```

www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
msfadmin@metasploitable:~$ _

```

User Enumeration

/etc/passwd was used to identify;

- System users
- Human users
- Service accounts
- Login-enabled accounts

Username	UID	Home Directory	Login Shell	Account Type
root	0	/root	/bin/bash	Administrator
msfadmin	1000	/home/msfadmin	/bin/bash	Normal User
postgres	108	/var/lib/postgresql	/bin/bash	Database Admin
user	1001	/home/user	/bin/bash	Normal User
service	1002	/home/service	/bin/bash	Normal User

Multiple accounts exist including service accounts.

Risk:

- Attackers can enumerate usernames
- Weak passwords can be targeted
- Unnecessary accounts increase attack surface

```
msfadmin@metasploitable:~$ sudo cat /etc/shadow
[sudo] password for msfadmin:
root:$1$/avpF8J1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$FUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
stdtd*:15474:0:99999:7:::
msfadmin@metasploitable:~$
```

The /etc/shadow file stores encrypted password hashes for local Linux accounts.

Password Hashes Identified

Accounts with actual password hashes are:

User	Hash Present	Hash Type
root	Yes	MD5 crypt (\$1\$)
sys	Yes	MD5 crypt (\$1\$)
klog	Yes	MD5 crypt (\$1\$)
msfadmin	Yes	MD5 crypt (\$1\$)
postgres	Yes	MD5 crypt (\$1\$)
user	Yes	MD5 crypt (\$1\$)
service	Yes	MD5 crypt (\$1\$)

MD5-based password hashing

Security issue:

MD5 is considered weak for password storage because it is:

- fast to compute
- vulnerable to offline cracking
- outdated

```
msfadmin@metasploitable:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
msfadmin@metasploitable:~$
msfadmin@metasploitable:~$
```



```
kali@kali:~$ ssh root@192.168.56.102
root@kali:~$ scp msfadmin@192.168.56.102:/home/msfadmin/shadow .
msfadmin@192.168.56.102's password:
shadow

root@kali:~$ cat shadow
root:16:0:root:/bin:/usr/sbin/passwd
daemon:*:1:1:daemon:/usr/sbin:/bin/sh
bin:*:2:2:bin:/bin:/bin/sh
sys:*:3:3:sys:/bin:/usr/sbin/passwd
sync:*:4:4:sync:/bin:/bin/sync
games:*:5:5:games:/usr/games:/bin/sh
man:*:6:6:man:/var/cache/man:/bin/sh
lp:*:7:7:lp:/var/spool/lpd:/bin/sh
mail:*:8:8:mail:/var/mail:/bin/sh
news:*:9:9:news:/var/spool/news:/bin/sh
uucp:*:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:*:11:11:proxy:/bin:/bin/sh
www-data:*:33:33:www-data:/var/www:/bin/sh
backup:*:34:34:backup:/var/backups:/bin/sh
list:*:38:38:List: Manager:/var/list:/bin/sh
irc:*:39:39:ircd:/var/run/ircd:/bin/sh
gnats:*:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:*:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:*:1000:101:/var/lib/libuuid:/bin/sh
hdcp:*:101:102:/nonexistent:/bin/false
syslog:*:102:103:/var/log:/bin/false
klog:*:1572766454890X1.CmLmduE3X9j0P0:103:104:/home/klog:/bin/false
nash:*:16165534:/var/run/nash:/usr/sbin/nologin
msfadmin:$1$XN10Zj2c$Rk7zZC3MltUWA.1hZJAS:1000:1000:msfadmin,,/home/msfadmin:/bin/bash
bind:*:185:113:/var/cache/bind:/bin/false
postfix:*:185:115:/var/spool/postfix:/bin/false
ftp:*:107:65534:/home/ftp:/bin/false
postgres:*:15963516.xMqgZu0Sp5a0vJ3nfCvE:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
mysql:*:180:180:MySQL Server:/var/lib/mysql:/bin/false
tomcat55:*:1101:65534:/usr/share/tomcat5.5:/bin/false
dirstd:*:111:65534:/:/bin/false
service:$1$H5u9r7qH.q0390900t1048PuzG0:1001:1001:just a user.111,,/home/user:/bin/bash
service:$1$K3uJ272576kEdup9S0pCjZ3u//:1002:1002,,/home/service:/bin/bash
telnetd:*:112:112:/nonexistent:/bin/false
proftpd:*:113:65534:/var/run/proftpd:/bin/false
stdat:*:114:65534:/var/lib/nfs:/bin/false

root@kali:~$
```

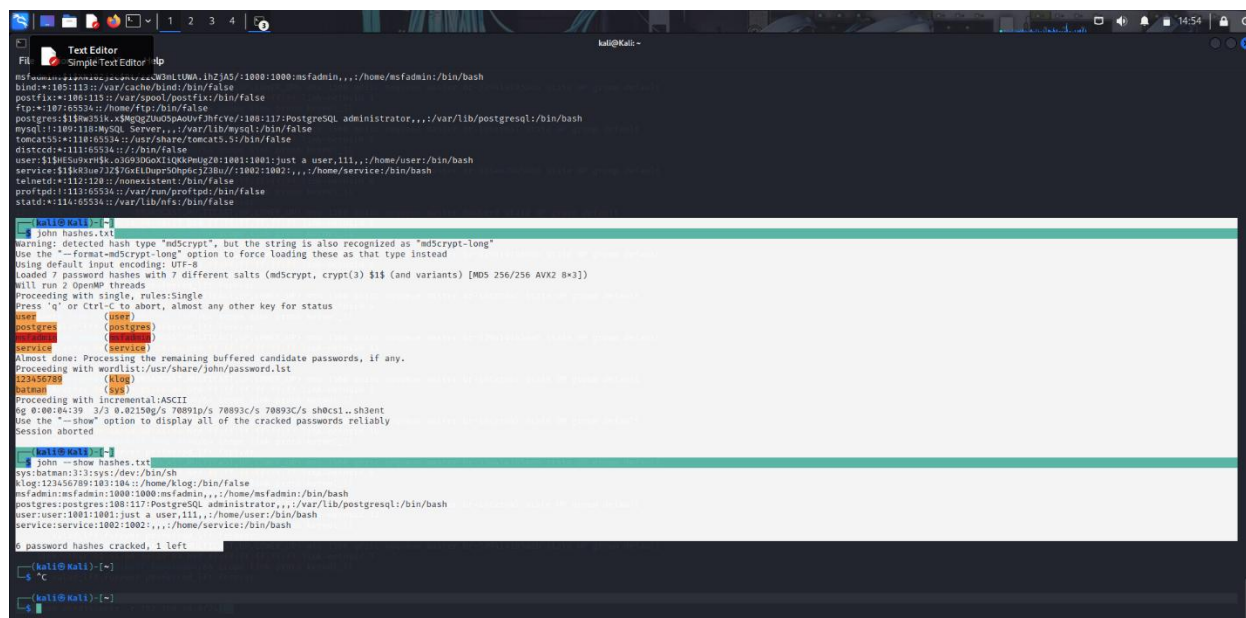
Password auditing revealed that 6 of the 7 password hashes were successfully cracked using John the Ripper. Several accounts used weak or default passwords such as "msfadmin", "postgres", "user", and "service". This indicates poor password hygiene and significantly increases the risk of unauthorized access through password attacks. One password remained uncracked during the assessment.

User Account	Password Recovered	Strength	Risk
user	user	Very Weak	High
postgres	postgres	Very Weak	High
msfadmin	msfadmin	Very Weak	High
service	service	Very Weak	High
klog	123456789	Weak	Medium
sys	batman	Weak	Medium

Impact:

An attacker who obtains password hashes could quickly recover user credentials and gain unauthorized access. User, postgres, msfadmin and service risks remains high because they are predictable credentials commonly used during initial installation and are easily guessed.

Find screenshot below;



```
MSFadmin:msfadmin:1000:1000:msfadmin,,,/home/msfadmin/bin/bash
bind*:*105:112::/var/cache/bind:/bin/false
postfix:*106:115::/var/spool/postfix:/bin/false
ftp:*107:65534::/home/ftp:/bin/false
postgres:*108:116::/usr/lib/postgresql/100:117:PostgreSQL administrator,,,/var/lib/postgresql/bin/bash
mysql:*109:118:MySQL Server,,,/var/lib/mysql/bin/false
tomcat55:*110:65534::/usr/share/tomcat5.5/bin/false
distcc:*111:65534::/bin/false
user:*112:Subaru0k.o369106x110KkPmgZ8:1001:1001:just a user,111,,,/home/user/bin/bash
service:*113:0x072187a710b0p00p0c22hu//:1002:1002::/home/service/bin/bash
telnetd:*114:128::/usr/lib/telnetd:/bin/false
proftpd:*115:65534::/var/run/proftpd/bin/false
statd:*116:65534::/var/lib/ntfs/bin/false

kali@kali:~$ john hashes.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
user          (user)
postgres      (postgres)
msfadmin      (msfadmin)
service       (service)
Almost done; Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456789     (1234)
Output
Proceeding with incremental:ASCII
eg 0:00:04:39  3/3 0.02150g/s 70893c/s 70893c/s shhcsl..shlent
Use the "--show" option to display all of the cracked passwords reliably
Session aborted

kali@kali:~$ john --show hashes.txt
user:batman:123456789:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
msfadmin:msfadmin:1000:1000:msfadmin,,,/home/msfadmin/bin/bash
postgres:postgres:100:117:PostgreSQL administrator,,,/var/lib/postgresql/bin/bash
user:user:1001:1001:just a user,111,,,/home/user/bin/bash
service:service:1002:1002::,/home/service/bin/bash

0 password hashes cracked, 1 left

kali@kali:~$
```

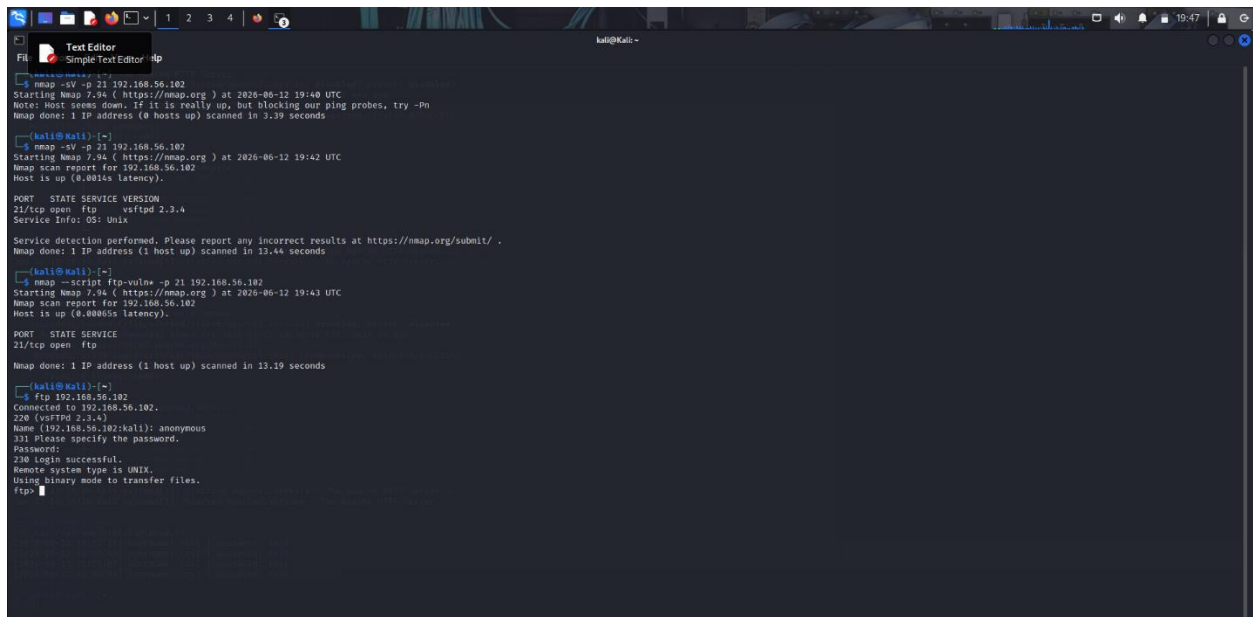
Recommendations

1. Enforce strong password policy:
 - Minimum 12 characters

- Complexity requirements
 - No dictionary words
2. Remove default passwords

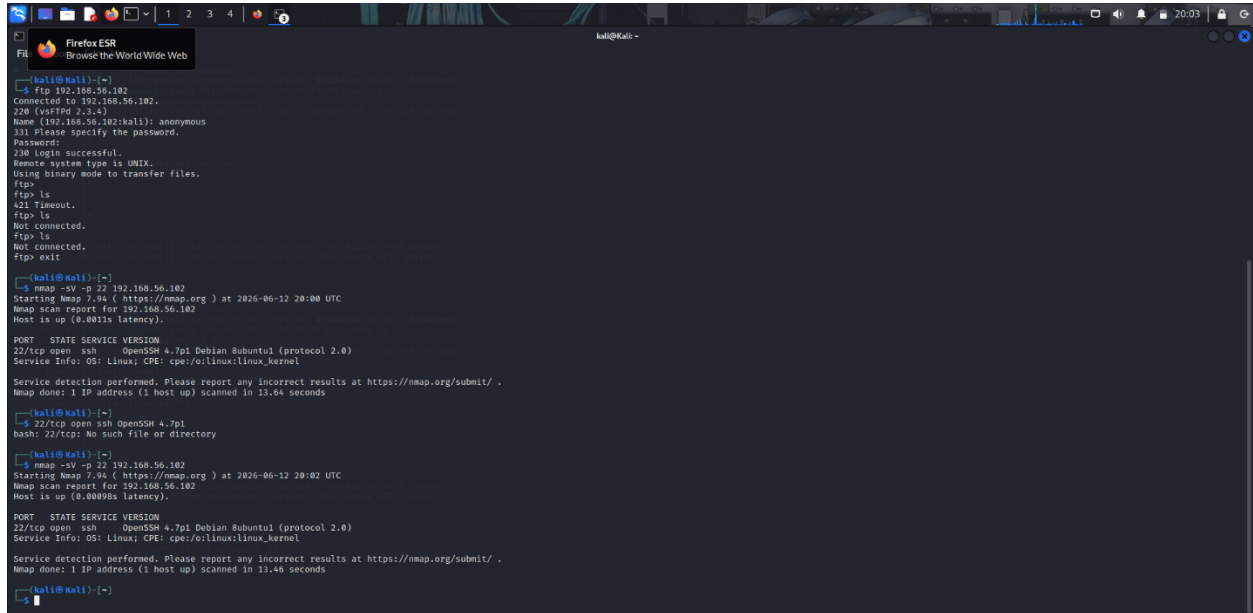
PHASE 3

FTP



```
kali@kali: ~  
$ nmap -sV -p 21 192.168.56.102  
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-12 19:40 UTC  
Notes: Host seems down, if it is really up, but blocking our ping probes, try -Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 3.39 seconds  
  
kali@kali: ~  
$ nmap -sV -p 21 192.168.56.102  
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-12 19:42 UTC  
Nmap scan report for 192.168.56.102  
Host is up (0.0014s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
Service Info: OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 13.44 seconds  
  
kali@kali: ~  
$ nmap -sV -p 21 192.168.56.102  
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-12 19:43 UTC  
Nmap scan report for 192.168.56.102  
Host is up (0.00065s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
  
Nmap done: 1 IP address (1 host up) scanned in 13.19 seconds  
  
kali@kali: ~  
$ ftp 192.168.56.102  
Connected to 192.168.56.102.  
220 (vsFTPD 2.2.4)  
Name (192.168.56.102:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

SSH



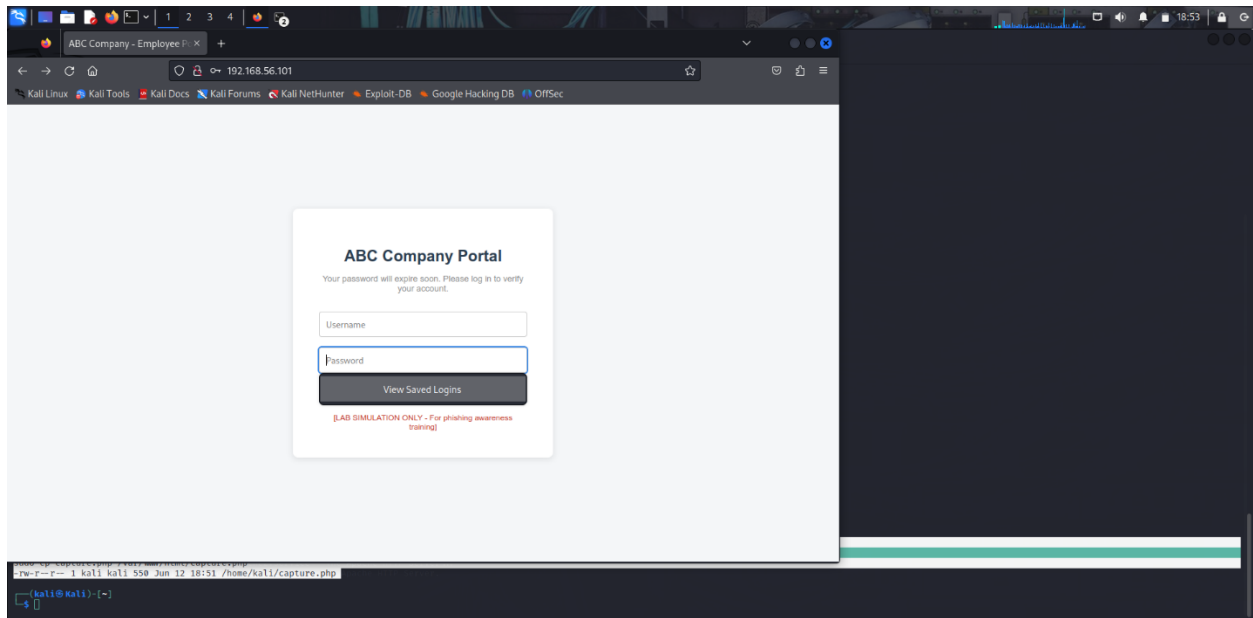
```
kali@kali: ~  
$ ftp 192.168.56.102  
Connected to 192.168.56.102.  
220 (vsFTPd 2.3.4)  
Name (192.168.56.102:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>  
ftp> ls  
421 Timeout.  
ftp> ls  
Not connected.  
ftp> ls  
Not connected.  
ftp> exit  
kali@kali: ~  
$ nmap -sV -p 22 192.168.56.102  
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-12 20:00 UTC  
Nmap scan report for 192.168.56.102  
Host is up (0.0011s latency).  
  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 13.64 seconds  
kali@kali: ~  
$ 22/tcp open ssh OpenSSH 4.7p1  
bash: 22/tcp: No such file or directory  
kali@kali: ~  
$ nmap -sV -p 22 192.168.56.102  
Starting Nmap 7.94 ( https://nmap.org ) at 2026-06-12 20:02 UTC  
Nmap scan report for 192.168.56.102  
Host is up (0.00098s latency).  
  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 13.46 seconds  
kali@kali: ~
```

PHASE 4

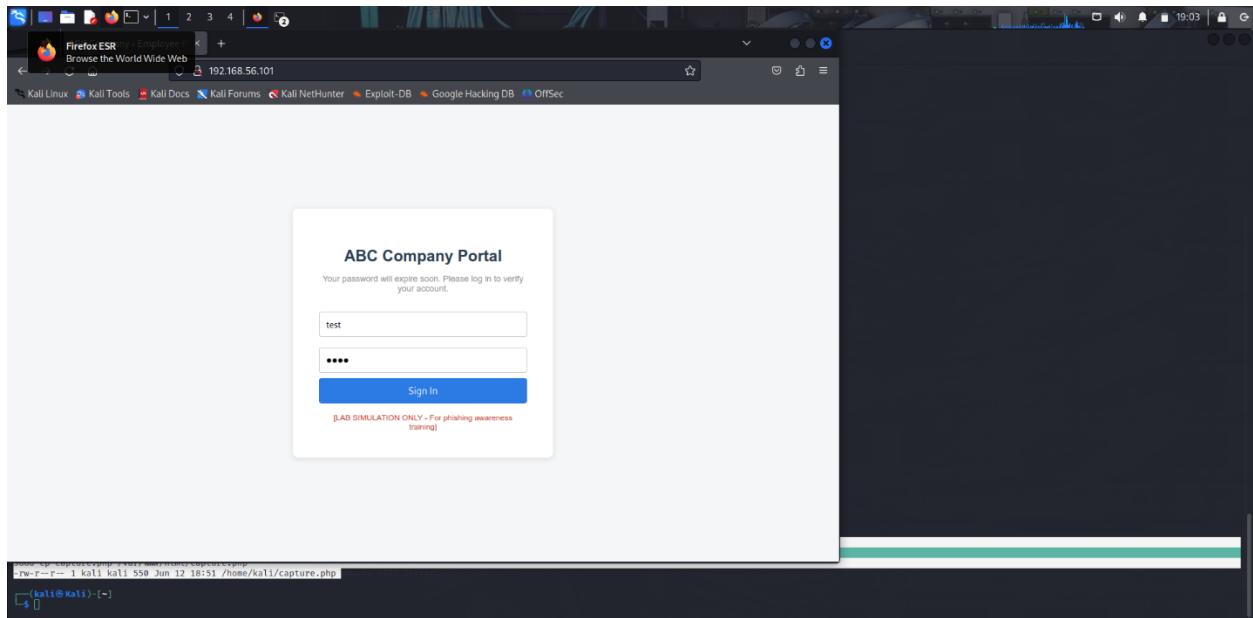
Social Engineering Awareness Assessment

Login Page

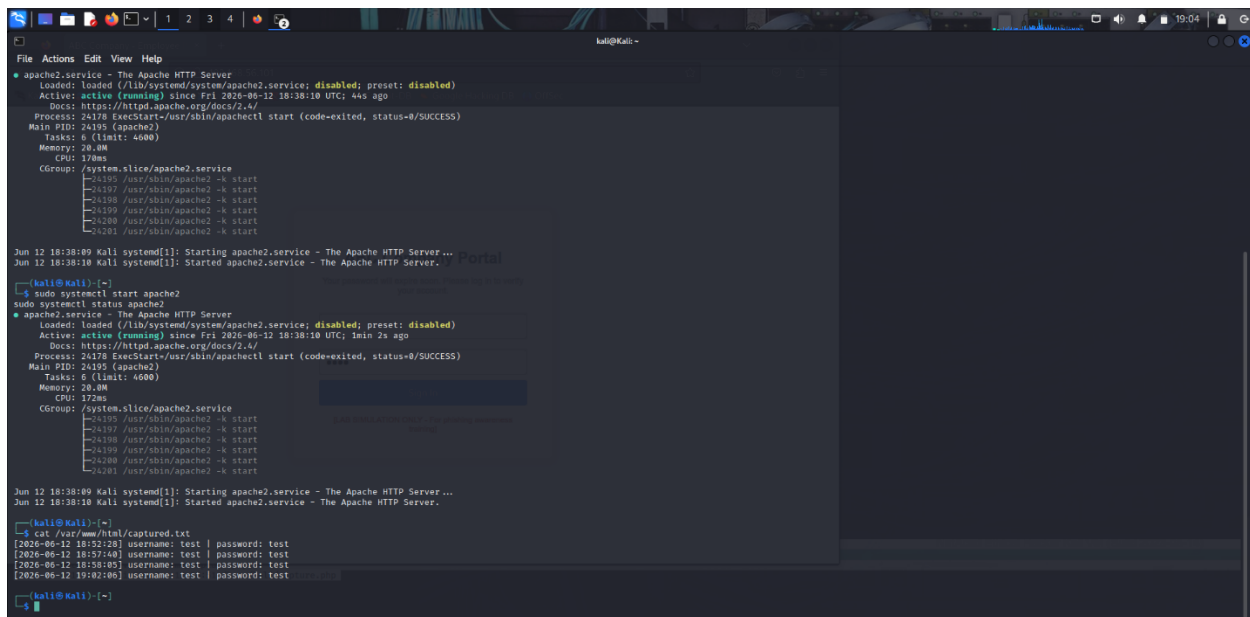
Shows the simulated "ABC Company Portal" login page as it appears to the target user, hosted at 192.168.56.101. The page uses an urgency-based message ("Your password will expire soon") to encourage immediate action, demonstrating the pretext used in the phishing simulation.



Shows the same login page with test credentials entered into the username and password fields, just before submission. This represents the user interaction stage of the attack the moment a real victim's credentials would be sent.



Shows the contents of captured.txt on the server, displaying the harvested username, password, and timestamp. This confirms the simulation successfully captured submitted credentials, demonstrating the potential impact of a real phishing attack.



```
File Actions Edit View Help
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Fri 2020-06-12 18:38:10 UTC; 44s ago
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 24178 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
    Main PID: 24195 (apache2)
       Tasks: 6 (limit: 4080)
         Memory: 20.0K
            CPU: 170ms
    CGroup: /system.slice/apache2.service
            └─24195 /usr/sbin/apache2 -k start
              └─24197 /usr/sbin/apache2 -k start
                └─24198 /usr/sbin/apache2 -k start
                  └─24199 /usr/sbin/apache2 -k start
                    └─24200 /usr/sbin/apache2 -k start
                      └─24201 /usr/sbin/apache2 -k start

Jun 12 18:38:09 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
Jun 12 18:38:10 kali systemd[1]: Started apache2.service - The Apache HTTP Server.

[kali@kali:~]$ sudo systemctl start apache2
$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Fri 2020-06-12 18:38:10 UTC; 1min 2s ago
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 24178 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
    Main PID: 24195 (apache2)
       Tasks: 6 (limit: 4080)
         Memory: 20.0K
            CPU: 172ms
    CGroup: /system.slice/apache2.service
            └─24195 /usr/sbin/apache2 -k start
              └─24197 /usr/sbin/apache2 -k start
                └─24198 /usr/sbin/apache2 -k start
                  └─24199 /usr/sbin/apache2 -k start
                    └─24200 /usr/sbin/apache2 -k start
                      └─24201 /usr/sbin/apache2 -k start

Jun 12 18:38:09 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
Jun 12 18:38:10 kali systemd[1]: Started apache2.service - The Apache HTTP Server.

[kali@kali:~]$ cat /var/www/html/captured.txt
[2020-06-12 18:52:28] username: test | password: test
[2020-06-12 18:57:48] username: test | password: test
[2020-06-12 18:58:05] username: test | password: test
[2020-06-12 19:02:06] username: test | password: test
```

Social Engineering Report

Technique Demonstrated

A credential-harvesting phishing simulation was conducted by deploying a fake "ABC Company Employee Portal" login page on an Apache web server (192.168.56.101). The page mimicked a legitimate internal login portal and used a "password expiring" urgency message to prompt user interaction. Submitted credentials were captured server-side via a PHP script and stored in a log file.

Attack Scenario

An employee receives a message (email or chat link) claiming their account password is about to expire and that they must log in immediately to avoid losing access. The link directs them to http://192.168.56.101/, which displays a convincing company-branded login form. The framing (urgency + routine IT request) is designed to bypass careful scrutiny.

User Interaction

The "victim" clicks the link, is presented with the cloned-style login page, and enters their username and password into the form. Upon clicking "Sign In," the credentials are silently transmitted via POST to capture.php, which logs them to captured.txt with a timestamp, while the user sees a generic "Authenticating..." message giving no indication anything unusual occurred.

Potential Impact

If real credentials were entered, an attacker would gain valid login details for the company portal or any system using the same credentials (due to password reuse). This could lead to account takeover, access to sensitive internal systems, lateral movement within the network, data exfiltration, or further targeted attacks using the compromised identity.

Awareness Analysis

Why would users trust the message?

The message uses authority and urgency a routine, plausible IT notice ("password expiring") that employees are conditioned to act on quickly. The page also visually matches a professional internal portal, reinforcing legitimacy.

What warning signs exist?

- Unsolicited request to "verify your account" via a link
- URL is a raw IP address (192.168.56.101) rather than a company domain
- No HTTPS/padlock credentials sent in plaintext
- Generic, slightly vague messaging ("Your password will expire soon")
- No personalization (e.g. no name, employee ID)

How could users detect the attack?

- Hover over or inspect the link before clicking an IP address or unfamiliar domain is a red flag

- Check for HTTPS and a valid certificate matching the company domain
- Navigate to the portal manually via a bookmark rather than clicking email links
- Verify the request through a separate channel (call IT directly)
- Be suspicious of urgency-based language

Defensive Measures

Multi-Factor Authentication (MFA): Even if credentials are phished, MFA (e.g. authenticator app, hardware token) prevents login without a second factor the attacker doesn't have, significantly reducing the impact of credential theft.

Email Security: Implementing SPF, DKIM, and DMARC reduces the chance of spoofed sender domains. Email filtering/sandboxing solutions can flag or block messages containing suspicious links before they reach users.

User Awareness Training: Regular, realistic phishing simulations (like this one) combined with training on identifying red flags build employee resilience. A clear, low-friction reporting mechanism encourages users to flag suspicious messages rather than ignore or act on them.

Password Managers: Password managers autofill credentials only on matching saved domains they won't autofill on a lookalike or IP-based phishing page, giving users a passive detection cue. They also reduce password reuse across systems, limiting the blast radius of any single credential compromise.

Indicators of Compromise (IOCs)

- Login page served from an unfamiliar IP/domain rather than the official company URL

- Absence of HTTPS on a page requesting credentials
- Entries appearing in captured.txt indicating successful credential capture
- Unusual/unauthorized login activity on the real portal shortly after the simulation, if real credentials were reused

Success Factors

- Convincing branding and urgency-based pretext
- Lack of HTTPS/domain verification by the user
- No prior awareness training on this specific lure

PHASE 5

1. Executive Summary

This engagement assessed an internal Linux server (Metasploitable2) on behalf of ParoCyber, covering information gathering, service enumeration, password security, vulnerability assessment, and employee susceptibility to phishing. The assessment found numerous critical and high-severity issues, including weak/default credentials, outdated and vulnerable services with known exploits, and successful credential capture during a phishing simulation. Overall risk level: Critical. The server in its current state could be fully compromised by an attacker with minimal effort, and employees demonstrated susceptibility to social engineering.

2. Findings

Information Gathering Findings

Port scanning revealed numerous open services exposed on the host, including FTP (21), SSH (22), Telnet (23), SMTP (25), DNS (53), HTTP (80), RPC (111), SMB (139/445), NFS (2049), MySQL (3306), PostgreSQL (5432), VNC

(5900), and IRC (6667). Many of these run outdated software versions, giving attackers a detailed map of potential entry points with minimal effort.

Password Findings

Default and weak credentials were identified on key services (e.g. msfadmin/msfadmin). Password auditing tools successfully cracked or brute-forced credentials within a short time frame, indicating inadequate password complexity policies and reuse of default vendor credentials.

Vulnerability Findings

Multiple services were found running versions with publicly known, exploitable vulnerabilities — including a backdoored FTP service (vsftpd 2.3.4), an exploitable Samba service (usermap_script), an exposed Java RMI service, and an UnrealIRCd backdoor. Several of these were successfully exploited using Metasploit to gain remote shell access, in some cases with root privileges.

Social Engineering Findings

A phishing simulation using a fake "company portal" login page successfully captured submitted credentials. The simulation exploited urgency-based messaging and visual similarity to a legitimate login page. The lack of HTTPS, use of a raw IP address, and absence of personalization were all detectable warning signs that were not flagged in the simulated interaction, indicating low awareness of phishing indicators.

3. Risk Analysis

Risk	Impact	Likelihood	Rating
Weak/Default Passwords	High	High	Critical
Outdated/Vulnerable Services (e.g. vsftpd, Samba, UnrealIRCd)	High	Medium	High

Risk	Impact	Likelihood	Rating
Unencrypted Services (Telnet, FTP)	High	Medium	High
Excessive Open Ports/Attack Surface	Medium	High	High
Successful Phishing Susceptibility	High	Medium	High
Misconfigured NFS/SMB Shares	Medium	Medium	Medium
Unpatched Database Services (MySQL/PostgreSQL)	Medium	Medium	Medium
Lack of MFA	High	High	Critical
Insecure VNC Access	Medium	Low	Medium
No Access Controls on Sensitive Files (e.g. captured.txt scenario)	Medium	Medium	Medium

4. Recommendations (Top 10)

1. Enforce strong password policies minimum length, complexity, and regular rotation; eliminate default vendor credentials immediately.
2. Implement Multi-Factor Authentication (MFA) across all remote access and administrative accounts.
3. Patch or decommission vulnerable services particularly vsftpd 2.3.4, Samba (usermap_script), UnrealIRCd, and Java RMI, all of which have known exploits.
4. Disable unnecessary services to reduce attack surface (e.g. Telnet, rlogin/rsh services, unused RPC services).
5. Replace unencrypted protocols (Telnet, FTP) with encrypted alternatives (SSH, SFTP/FTPS).
6. Restrict and audit NFS/SMB share permissions to prevent unauthorized access to sensitive files.

7. Conduct regular vulnerability scanning and patch management as an ongoing process, not a one-time activity.
8. Roll out phishing awareness training with recurring simulated phishing campaigns to build employee detection skills.
9. Deploy email security controls (SPF, DKIM, DMARC, and link/attachment filtering) to reduce phishing delivery success.
10. Encourage password manager adoption organization-wide to reduce password reuse and provide a passive phishing detection mechanism.

5. Conclusion

The assessed server exhibits a critical overall security posture, driven primarily by weak authentication practices, multiple unpatched services with publicly available exploits, and a workforce vulnerable to phishing. While individually some findings (e.g. outdated database versions) pose moderate risk, the combination of weak credentials, exploitable services, and successful social engineering creates a high likelihood of full system compromise if these conditions exist in a production environment. Addressing the top recommendations particularly password policy enforcement, MFA, and patching of exploitable services would substantially reduce ParoCyber's exposure. Ongoing monitoring, patch management, and security awareness training should be institutionalized rather than treated as one-time fixes.

